

Política de Segurança para Windows

DEUSINETE DE JESUS DUTRA

Disciplina: Sistema Operacional.

Política de Segurança para Sistemas Operacionais Windows

1. INTRODUÇÃO

A Política de Segurança da Informação é um documento normativo que estabelece os princípios, diretrizes e práticas necessárias para proteger os ativos informacionais de uma organização. Está fundamentada nos princípios da segurança da informação da norma ISO/IEC 27001 e segue as boas práticas recomendadas pela NIST SP 800-53. Visa garantir a confidencialidade, integridade e disponibilidade da informação, além de garantir o uso adequado das informações, mitigar riscos operacionais. Para isso, é fundamental estabelecer papéis e responsabilidades de forma clara e objetiva; definir diretrizes técnicas e administrativas para proteção da informação, implementar mecanismos de monitoramento e auditoria para verificar a eficácia dos controles adotados.

No contexto específico dos sistemas operacionais Microsoft Windows, esta política define as diretrizes de segurança aplicáveis à sua configuração, uso e manutenção no ambiente organizacional. Seu propósito é proteger os ativos digitais contra acessos não autorizados, vazamentos de dados, códigos maliciosos, falhas de configuração e outras ameaças, promovendo um ambiente seguro e confiável.

2. ESCOPO

Aplica-se a todos os computadores, servidores e dispositivos que utilizem o sistema operacional Windows, incluindo versões desktop e servidor, em ambientes locais ou remotos.

3. REFERÊNCIAS NORMATIVAS

- ISO/IEC 27000 - Vocabulário de Gestão da Segurança da Informação
- ISO/IEC 27001 – Sistema de Gestão de Segurança da Informação
- ISO/IEC 27002 - Tecnologia da informação - Técnicas de segurança
- NIST SP 800-53 – Controles de Segurança e Privacidade

4. DEFINIÇÕES E TERMOS

ACL (Access Control List): Lista de controle de acesso que define permissões por usuário ou grupo;

BITLOCKER: Tecnologia de criptografia de disco da Microsoft;

ACESSO INDEVIDO: Ato de acessar informações, sistemas, serviços ou recursos sem autorização válida, violando regras de controle de acesso ou permissões estabelecidas.

INCIDENTE: Evento ou série de eventos indesejados ou inesperados que comprometeram ou têm o potencial de comprometer as operações do negócio e a segurança da informação;

VULNERABILIDADE: Fraqueza de um ativo, controle ou processo que pode ser explorada por uma ameaça, resultando em impacto negativo para a organização;

ENGENHARIA SOCIAL: Técnica usada para manipular pessoas visando obter informações, acesso ou executar ações que comprometem a segurança da informação;

DISPONIBILIDADE: propriedade pela qual se assegura que a informação esteja acessível e utilizável, sob demanda, por uma pessoa física ou determinado sistema, órgão ou entidade devidamente autorizados;

INFORMAÇÃO: Dados organizados em um contexto específico e que possuem significado, valor ou utilidade para a organização, contidos em qualquer meio, suporte ou formato;

INTEGRIDADE: Propriedade que garante que a informação não foi alterada, destruída ou modificada de maneira não autorizada, mantendo sua precisão e completude;

CONFIDENCIALIDADE: Propriedade que assegura que a informação está acessível somente a pessoas, sistemas ou entidades autorizadas;

AUTENTICIDADE: Propriedade que garante que uma entidade (usuário, sistema, informação ou origem de um dado) é genuína e foi devidamente verificada.

AUTENTICAÇÃO: é o processo de verificação da identidade de um usuário, sistema ou entidade.

5. DIRETRIZES DE SEGURANÇA

Estabelece diretrizes para garantir a segurança dos sistemas operacionais Windows

5.1 Política de Senhas

- Tamanho mínimo: 12 caracteres
- Complexidade: obrigatoriedade de letras maiúsculas, minúsculas, números e caracteres especiais
- Expiração: a cada 90 dias
- Histórico: impedir reutilização das últimas 5 senhas
- Bloqueio automático após 4 tentativas de login mal-sucedidas

5.2 Autenticação

- Login com credenciais individuais e intransferíveis;
- Autenticação multifator (2FA) obrigatória para: Acesso remoto via VPN, acesso em nuvem, ao e-mail corporativo e acesso a sistemas administrativos;
- Bloqueio de conta após 4 tentativas consecutivas de login inválido com duração de bloqueio de 30 minutos

5.3 Controle de Permissões

- Uso de grupos de usuários para atribuição de permissões;
- Aplicação de ACLs para restringir acesso a arquivos, pastas e recursos;
- Princípio do menor privilégio: conceder apenas as permissões necessárias.

5.4 Acesso Externo

- Acesso remoto permitido apenas via VPN corporativa
- Restrições de acesso via RDP (Remote Desktop Protocol): Apenas para usuários autorizados, evitar uso de contas com privilégios elevados, permitir RDP apenas de IPs confiáveis, exigir conexão VPN antes de permitir sessões RDP, aplicar atualizações regulares, monitoramento de sessões e eventos e ativar logs de auditoria;
- Configuração de NAT para ocultar IP's internos e limitar exposição: Evitar NAT estático desnecessário, combinar com regras de firewall para bloquear portas e protocolos não utilizados e registrar conexões NAT para fins de auditoria e resposta a incidentes

5.5 Firewall e Proxy

- FIREWALL: Ativação do Windows Firewall em todos os dispositivos, negar por padrão (default deny), utilizar firewalls internos para segmentar a rede por função (ex.: servidores, usuários,

convidados), criar regras com base em IP, porta, protocolo e horário, bloquear portas e serviços não utilizados, ativar o registro de eventos e analise logs regularmente, manter o firmware e o sistema do firewall atualizados (Atualizações e patches) e permitir acesso à interface de gerenciamento do firewall somente por autorizados.

- PROXY: Filtrar conteúdos (sites maliciosos, domínios não autorizados), exigir autenticação para uso do proxy, manter registro e auditoria de navegação (Mantenha logs detalhados de acesso à internet.), limitar downloads e uploads (ex.: .exe, .bat), integrar com antivírus (Analisar arquivos em tempo real antes de liberá-los para download), usar proxy explícito para maior controle e autenticação, além de manter listas de bloqueio e filtros atualizados.

5.6 Antivírus e Antimalware

Instalação obrigatória de software antivírus corporativo (ex.: Microsoft Defender for Endpoint, Kaspersky, Bitdefender), atualizações automáticas diárias de assinaturas e verificações completas semanais e em tempo real.

5.7 Controle de Portas

Habilitar apenas portas necessárias para operação, desativar portas não utilizadas via Windows Firewall e monitoramento contínuo de tráfego por portas vulneráveis

5.8 Política de Backup

- Backups diários e mensal automáticos
- Armazenamento em nuvem criptografada
- Criptografar os arquivos de backup em trânsito e em repouso
- Restringir acesso aos backups apenas a usuários autorizados
- Realizar testes de restauração realizados mensalmente, documentar os resultados e ajustar processos conforme necessário
- Definir prazos de retenção conforme exigências legais e operacionais. Realizar descarte seguro de mídias e arquivos obsoletos (ex.: destruição física ou sanitização digital).

5.9 Criptografia de Senhas e Dados

Criptografia de disco com BitLocker em todos os dispositivos móveis e notebooks, uso de certificados digitais para autenticação e assinatura de documentos e armazenamento seguro de senhas com algoritmos de hash robustos

5.10 Tokens e 2FA

Utilização de tokens físicos ou aplicativos autenticadores (ex.: Microsoft Authenticator, Google Authenticator), sendo obrigatório para: Acesso remoto, E-mail corporativo e Sistemas administrativos e financeiros

5.11 Treinamento de Usuários

Implementação de programas de conscientização em segurança da informação que promovam a educação contínua dos usuários, abordando temas como phishing e engenharia social, boas práticas de criação e gerenciamento de senhas, além do uso seguro de dispositivos, sistemas e redes, entre outros aspectos essenciais para o fortalecimento da postura de segurança organizacional.

6. RESPONSABILIDADES

Conforme a ISO/IEC 27001, “a organização deve atribuir responsabilidades e autoridades para assegurar que os papéis de segurança da informação sejam desempenhados de forma eficaz e que os controles sejam aplicados conforme planejado.”

6.1 Usuários

Seguir as diretrizes da política, reportar incidentes, manter senhas seguras e confidenciais, bem como participar de treinamentos de segurança e conscientização;

6.2 Administradores de sistemas

Profissionais responsáveis pela configuração, manutenção e segurança dos sistemas Windows. Compete a esses administradores: implementar e manter controles técnicos (como GPOs, ACLs e criptografia); gerenciar contas de usuários e suas permissões; monitorar logs e eventos de segurança; aplicar atualizações e patches de forma regular; e realizar testes periódicos de backup e restauração.

6.3 Gestores de área

São responsáveis pela supervisão das políticas de segurança e pela tomada de decisões estratégicas relacionadas à proteção da informação, incluindo a aprovação e revisão das políticas de segurança, a garantia de recursos necessários para a implementação dos controles, a avaliação dos riscos e impactos associados à segurança da informação e a promoção de uma cultura organizacional voltada à proteção dos dados, além de garantir recursos para implementação e manutenção da política.

6.4 Equipe de Segurança da Informação

São responsáveis pela supervisão das políticas de segurança e pela tomada de decisões estratégicas relacionadas à proteção da informação. Suas atribuições incluem aprovar e revisar as políticas de segurança, assegurar os recursos necessários para a implementação dos controles, avaliar riscos e impactos associados à segurança da informação e promover uma cultura organizacional voltada para a conscientização e proteção dos dados.

7. GESTÃO DE INCIDENTES

processo de tratamento de incidentes de segurança deve garantir o registro completo e a análise adequada de cada ocorrência, permitindo identificar causas, impactos e medidas necessárias. Qualquer indício ou confirmação de incidente deve ser comunicado imediatamente à equipe de TI ou ao time responsável pela gestão de incidentes, assegurando resposta rápida e coordenada. As ações corretivas e preventivas adotadas devem ser formalmente documentadas, de modo a reforçar a melhoria contínua e evitar a recorrência de situações semelhantes.

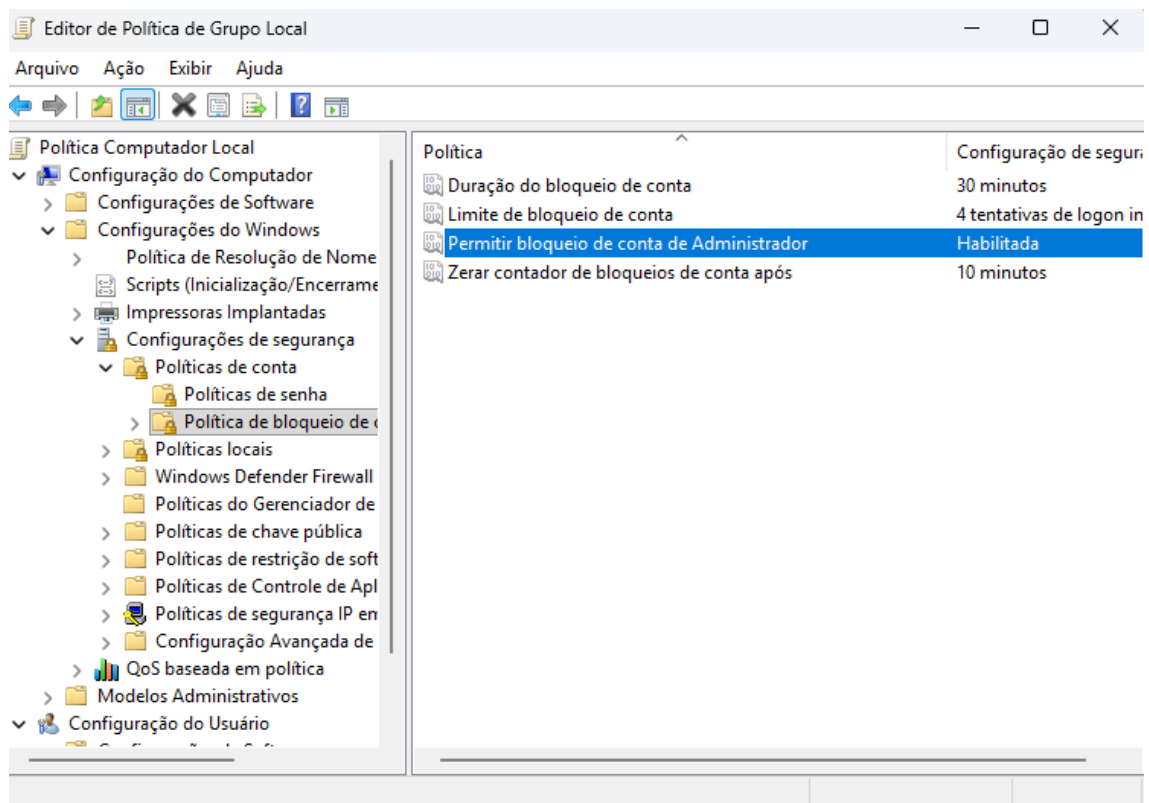
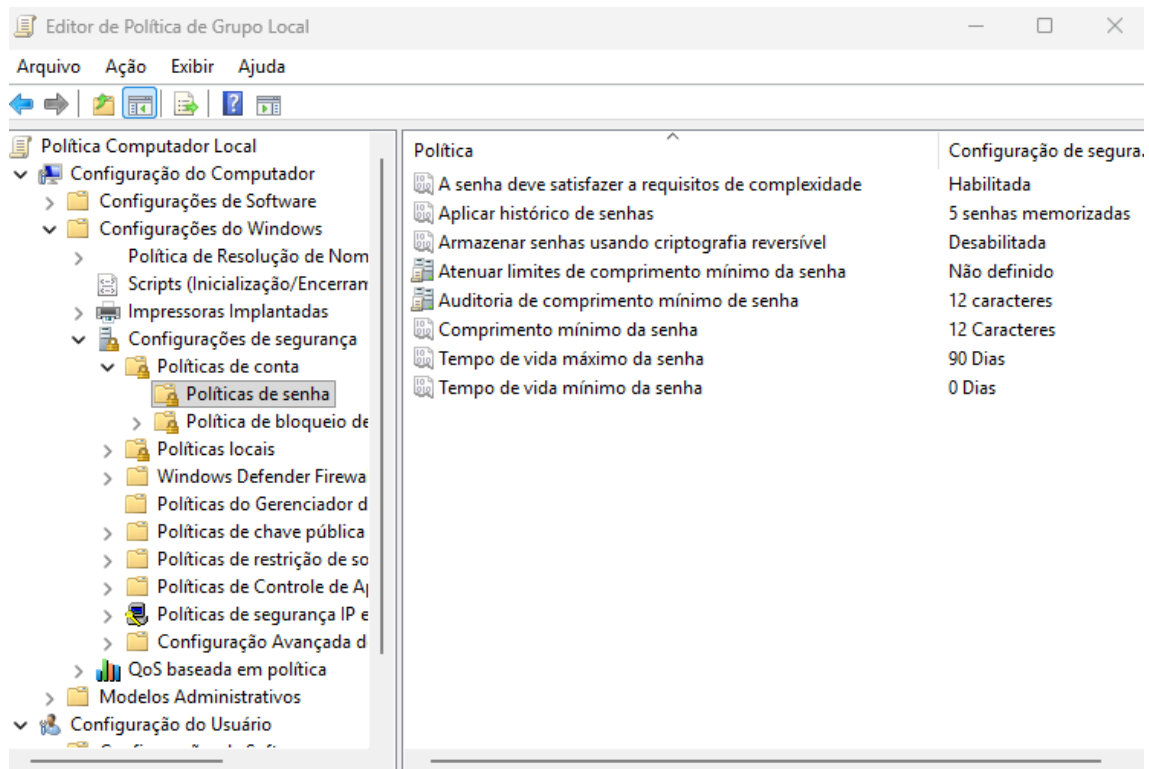
8. REVISÃO DA POLÍTICA

A política deve ser revisada anualmente ou sempre que houver mudanças relevantes no ambiente tecnológico, sendo a Equipe de Segurança da Informação responsável por conduzir esse processo.

9. TERMO DE COMPROMISSO

Todos os colaboradores devem assinar o termo de ciência e concordância com esta política que será enviado por email para assinatura eletrônica.

1. Senha e autenticação via *gpedit.msc*.



2. Firewall e controle de portas com bloqueio/liberação de regras

 Assistente para Nova Regra de Entrada ✕

Protocolo e Portas

Especifique os protocolos e as portas a que a regra se aplica.

Etapas:

- Tipo de regra
- Protocolo e Portas**
- Ação
- Perfil
- Nome

Essa regra se aplica a TCP ou a UDP?

☒ **TCP**

☐ **UDP**

Essa regra se aplica a todas as portas locais ou a portas locais específicas?

☐ **Todas as portas locais**

☒ **Portas locais específicas:**

Exemplo: 80, 443, 5000-5010

 Assistente para Nova Regra de Entrada ✕

Ação

Especifique a ação executada quando uma conexão atender às condições especificadas na regra.

Etapas:

- Tipo de regra
- Protocolo e Portas
- Ação**
- Perfil
- Nome

Que ação deve ser tomada quando uma conexão corresponde às condições especificadas?

☐ **Permitir a conexão**

Isso inclui conexões protegidas com IPsec bem como as sem essa proteção.

☐ **Permitir a conexão, se for segura**

Isso inclui conexões que foram autenticadas usando IPsec. As conexões serão protegidas por meio de uso das configurações nas regras e propriedades IPsec no nó Regra de Segurança de Conexão.

☒ **Bloquear a conexão**

 Assistente para Nova Regra de Entrada ✕

Perfil

Especificar os perfis aos quais essa regra se aplica.

Etapas:

- Tipo de regra
- Protocolo e Portas
- Ação
- Perfil**
- Nome

Quando esta regra se aplica?

☒ **Domínio**

Aplica-se quando um computador está conectado ao seu domínio corporativo.

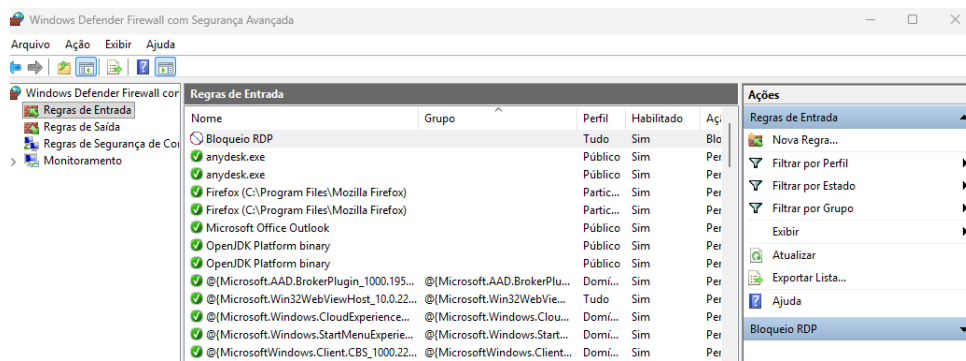
☒ **Particular**

Aplica-se quando um computador está conectado a um local de rede privada, como residência ou local de trabalho.

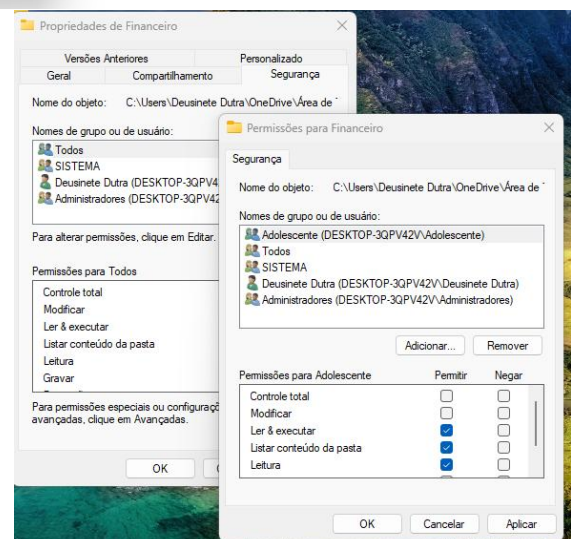
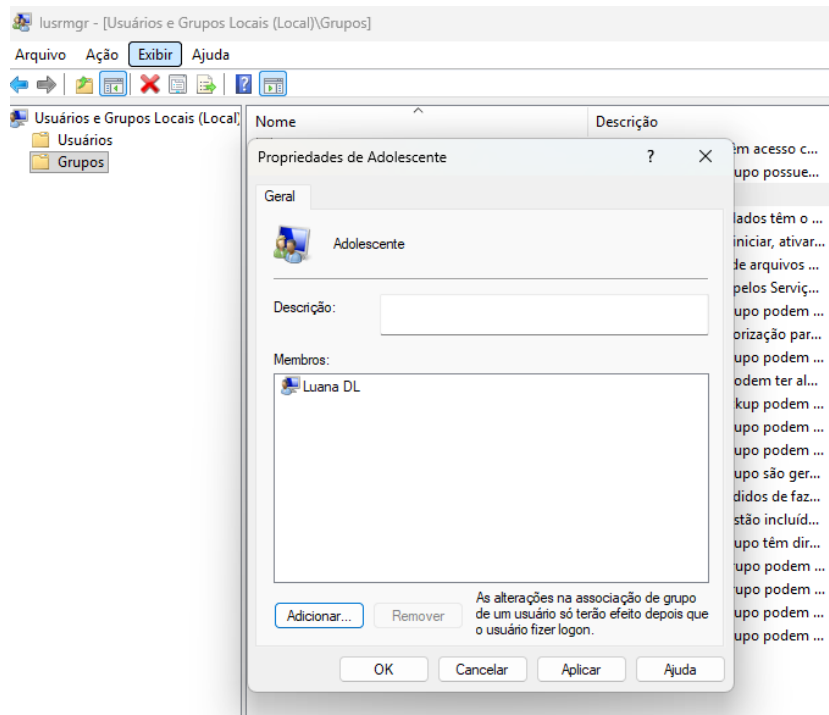
☒ **Público**

Aplica-se quando um computador está conectado a um local de rede pública.

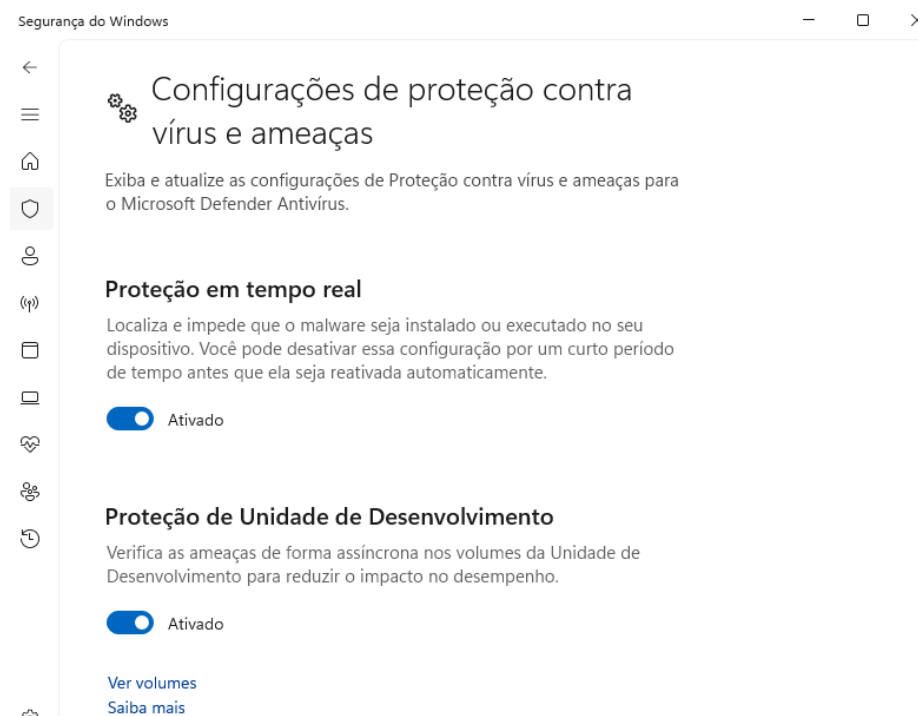
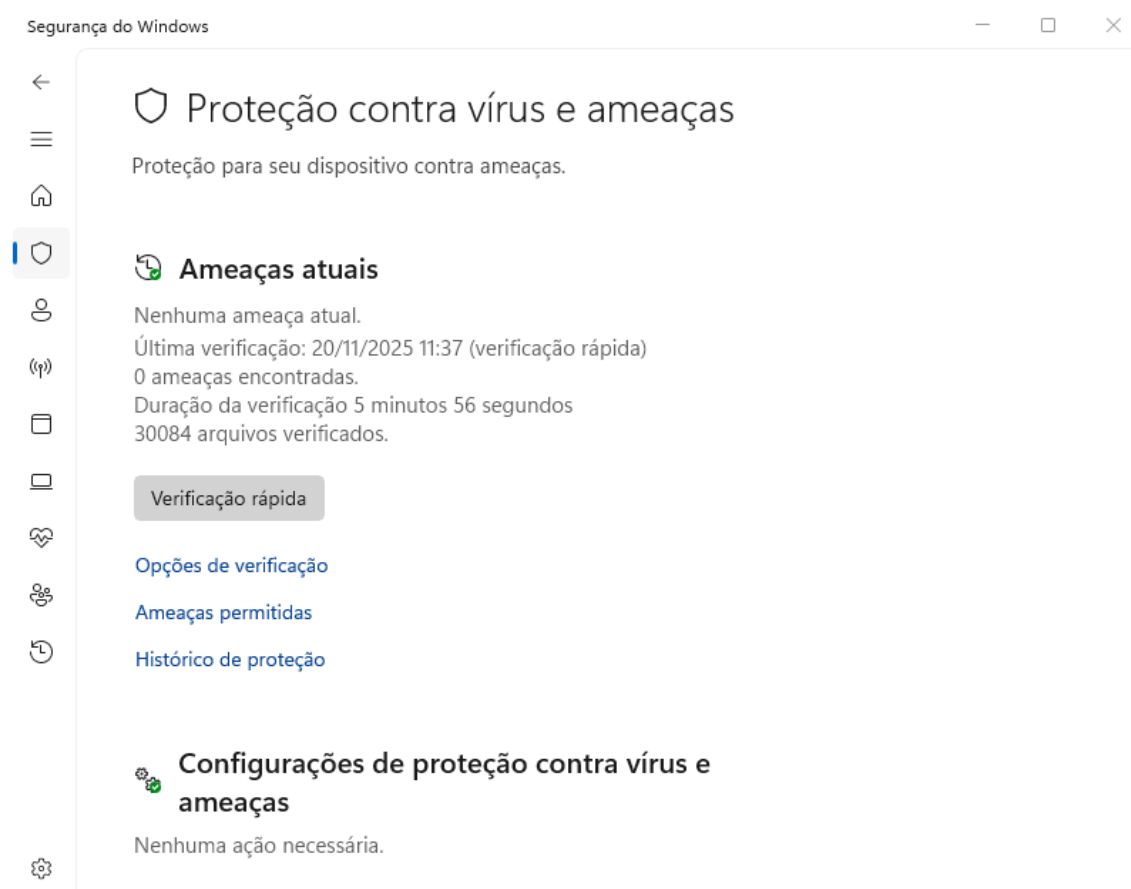
Criada nova regra: bloqueio RDP



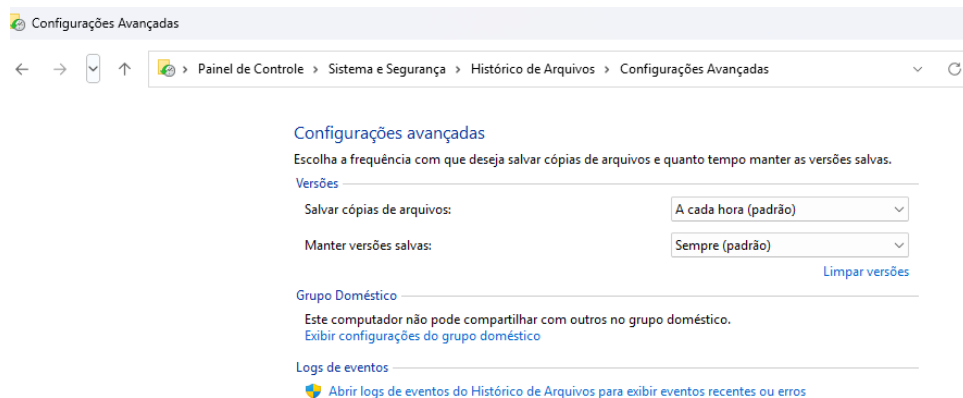
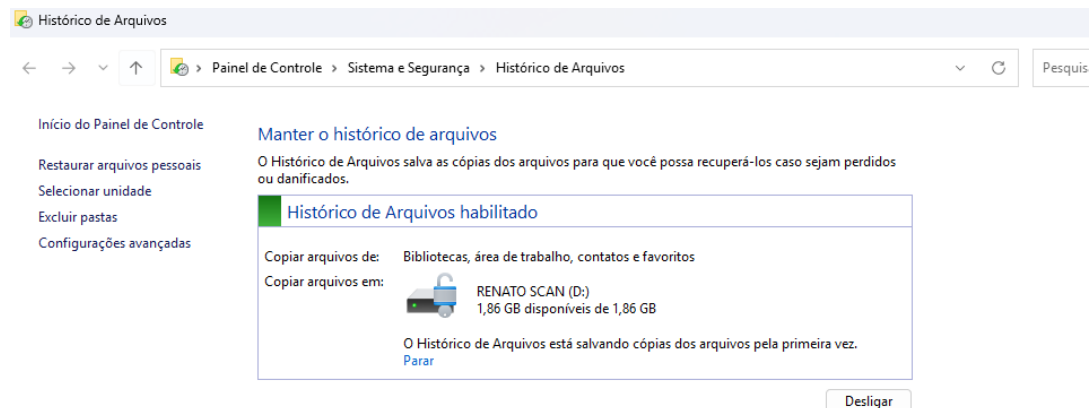
3. Controle de permissões em pastas com usuários diferentes



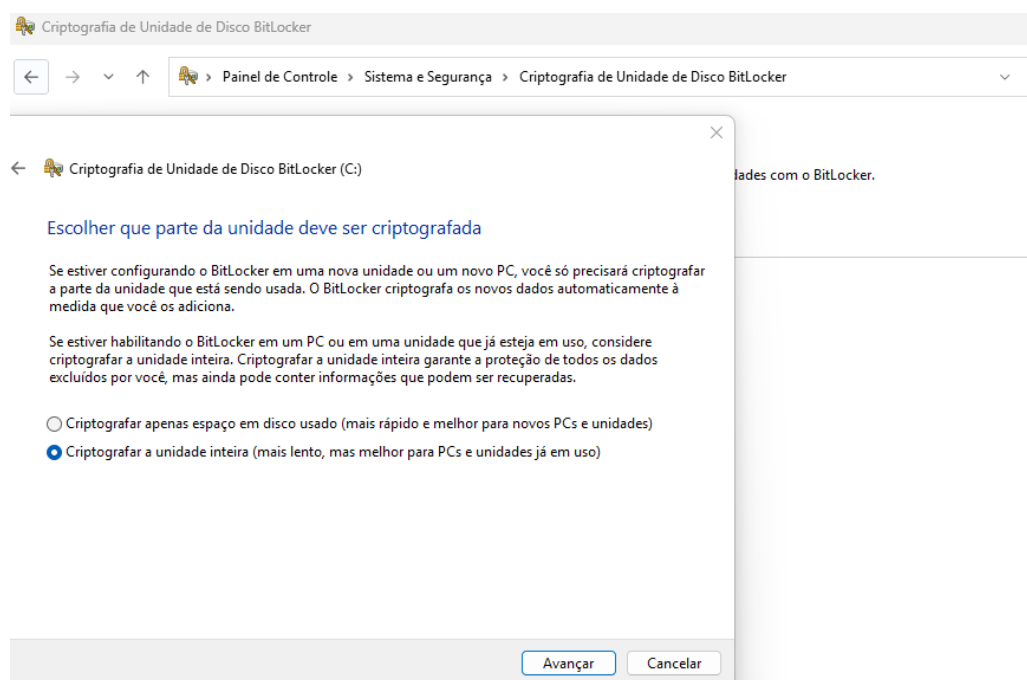
4. Antivírus com Microsoft Defender ou similar.

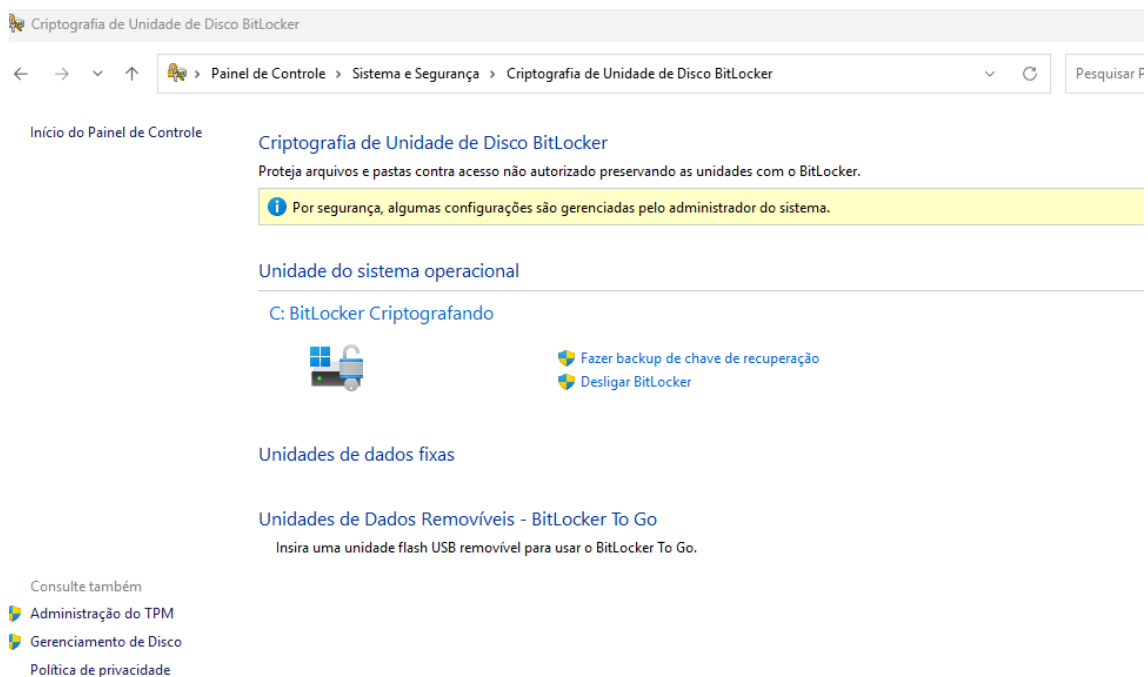
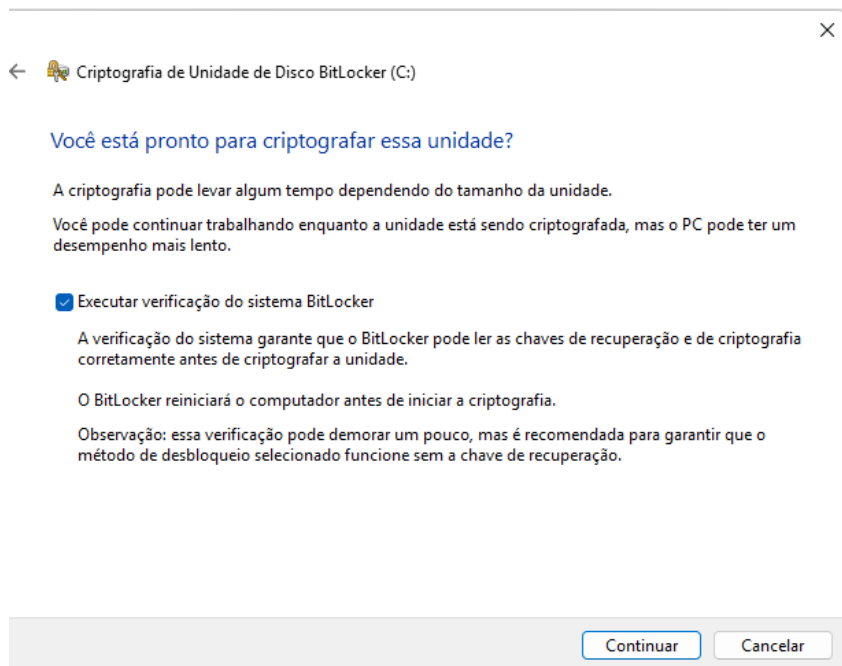


5. Backup com Histórico de Arquivos ou agendamento.



6. Criptografia e Token com BitLocker e simulação de 2FA





Exigir autenticação adicional na inicialização (Windows Server 2008 e Windows Vista)

Exigir autenticação adicional na inicialização (Windows Server 2008 e Windows Vista)

Configuração Anterior

Próxima Configuração

☐ Não Configurado

☒ Habilitado

☐ Desabilitado

Comentário:

Aceito em:

Windows Server 2008 e Windows Vista

Opções:

Ajuda:

Permitir o BitLocker sem um TPM compatível

☒ (exige uma senha ou uma chave de inicialização em uma unidade flash USB)

Configurações para computadores com um TPM:

Configurar chave de inicialização de TPM:

Permitir chave de inicialização com TPM

Configurar PIN de inicialização de TPM:

Permitir PIN de inicialização com TPM

Importante: se você exigir uma chave de inicialização, não poderá permitir o PIN de inicialização.

Se você exigir um PIN de inicialização, não poderá permitir uma chave de inicialização. Caso contrário,

Essa configuração de política permite controlar se o Assistente para Instalação da Criptografia de Unidade de Disco BitLocker poderá configurar um método de autenticação adicional que será solicitado sempre que o computador for iniciado. Essa configuração de política é aplicada ao ativar o BitLocker.

Observação: essa política só é aplicável aos computadores executando o Windows Server 2008 ou o Windows Vista.

Em um computador com um TPM compatível, dois métodos de autenticação podem ser usados na inicialização para oferecer proteção adicional de dados criptografados. Quando o computador é iniciado, ele pode exigir que os usuários insiram um pen drive que contém uma chave de inicialização. Ele também pode exigir que os usuários insiram um PIN (número de identificação pessoal) de inicialização de 4 a 20 dígitos.

Um pen drive que contém uma chave de inicialização é necessário em computadores que não possuem um TPM compatível. Sem um TPM, os dados criptografados por BitLocker

OK

Cancelar

Aplicar



ndutra@hotmail.com

Verifique seu aplicativo Authenticator



98

Selecione esse número na solicitação de entrada em seu dispositivo móvel.

[Outras maneiras de entrar](#)



Política de Segurança para Windows

DEUSINETE DE JESUS DUTRA

Disciplina: Sistema Operacional.
ADS | UNIRUY

**RELATÓRIO DE DIAGNÓSTICO DE SEGURANÇA DO SISTEMA OPERACIONAL WINDOWS
FACULDADE MEDICINAFTC**

Deusinete de Jesus Dutra

1. INTRODUÇÃO

O presente relatório tem como objetivo avaliar o nível de segurança da informação no ambiente Windows da faculdade MedicinaFTC, com base nos dados coletados por meio da aplicação de dois questionários de diagnóstico. A análise está organizada de acordo com os pilares fundamentais da segurança — Política, Tecnologia e Pessoas — e busca identificar pontos fortes, vulnerabilidades e riscos associados, além de propor um plano de ação que contribua para a melhoria contínua da segurança na organização.

2. CENÁRIO ATUAL E PONTOS FORTES

A Instituição demonstra uma maturidade de segurança acima da média em diversos aspectos. O ambiente já possui várias políticas e controles técnicos implementados.

Área	Controle Implementado	Detalhes
Política de Senhas	Implementada e robusta.	Exigência de 9 caracteres, complexidade, expiração a cada 180 dias, impedimento de reutilização e carência de 6 ciclos.
Autenticação (2FA)	Implementada em sistemas críticos.	Utilizada no Office 365 através de aplicativo autenticador e SMS
Firewall	Ativo e configurado.	Ativo em todos os equipamentos com regras de bloqueio de portas não utilizadas e revisão periódica.
Antivírus	Centralizado e atualizado.	Uso do Microsoft Defender, instalado e atualizado automaticamente em todas as máquinas, com monitoramento centralizado.
Backup	Rotina de backup rigorosa.	Frequência diária, semanal e mensal, tipos completo e diferencial, armazenamento em nuvem (externo e seguro) e testes de restauração regulares.

Área	Controle Implementado	Detalhes
Criptografia	Uso de soluções nativas.	Uso de BitLocker e certificados digitais.
Conscientização	Treinamento ativo.	Usuários recebem treinamento sobre segurança, phishing e boas práticas de senha.
Registro de Acessos Externos	Controlado e auditado	Registro de Acessos Externos, o acesso por RDP é restrito apenas à equipe autorizada, existe Registro e monitoramento dos acessos.

3. IDENTIFICAÇÃO DE VULNERABILIDADES E RISCOS

Apesar dos pontos fortes, a análise revela algumas vulnerabilidades e inconsistências que precisam ser endereçadas.

Item	Vulnerabilidade	Detalhes
1.	Ausência de ACLs (Listas de Controle de Acesso)	O controle de permissões em pastas é feito, mas o questionário indica explicitamente que ACLs não são utilizadas. Isso sugere que o gerenciamento de permissões pode ser manual, sem padrão ou via herança simples, dificultando a granularidade e a revisão.
2.	Fragilidade na Gestão de Permissões	Não foi especificado quem é responsável pela revisão trimestral das permissões. A falta de clareza na responsabilidade pode levar à negligência.
3.	Desbloqueio de Conta manual	O bloqueio de conta após 3 tentativas é uma boa prática, mas o desbloqueio é <i>apenas</i> manual pelo administrador. Isso aumenta a carga operacional (trabalho) da equipe de TI e pode gerar indisponibilidade desnecessária ao usuário fora do horário comercial.
4.	Foco na Conscientização	A equipe de TI identifica a Conscientização dos Usuários como o principal desafio. Isso indica que, apesar dos treinamentos, o fator humano continua sendo o elo mais fraco e uma fonte constante de risco (ex: clique em links de <i>phishing</i>).

Riscos Associados

1. **Risco de Acesso Excessivo (Vulnerabilidade 1):** A não utilização de ACLs de forma estruturada pode resultar em usuários com mais permissões do que o necessário (Princípio do Mínimo Privilégio), aumentando o risco de exclusão acidental ou acesso indevido a dados sensíveis.
2. **Risco de Indisponibilidade (Vulnerabilidade 3):** Em caso de múltiplas tentativas falhas fora do horário comercial, o usuário legítimo não consegue acessar seus recursos até que um administrador intervenha.
3. **Risco de Incidente (Vulnerabilidade 4):** A fragilidade na conscientização eleva a probabilidade de um ataque de engenharia social ser bem-sucedido, o que pode anular todos os controles técnicos.

4. PLANO DE AÇÃO E SUGESTÕES DE MELHORIA

As seguintes ações são sugeridas para mitigar as vulnerabilidades e reforçar a segurança do ambiente Windows da Faculdade MedicinaFTC.

Melhorias Estruturais e Técnicas

Prioridade	Ação Sugerida	Detalhes
Alta	Implementar ACLs Estruturadas via Grupos	Reestruturar o controle de permissões (ACLs) utilizando o modelo de grupos do Windows (ex: modelo AGDLP ou AGUDLP), aplicando o Princípio do Mínimo Privilégio de forma mais granular e auditável.
Média	Definir Responsável pela Revisão	Definir e documentar de forma clara, na Política de Segurança da Informação ou em procedimento específico, as responsabilidades dos papéis envolvidos (Ex.: Coordenador de TI, Administrador de Sistemas) incluindo a atribuição da responsabilidade pela revisão trimestral das permissões.
Média	Aprimorar Bloqueio de Contas	Configurar o bloqueio de contas para incluir desbloqueio automático após um período de tempo razoável, em complemento ao desbloqueio manual, para balancear segurança e disponibilidade.
Baixa	Concluir 2FA	Finalizar a implantação do 2FA no sistema acadêmico Lyceum, conforme já previsto.

Ações Focadas em Pessoas (Mitigação do Desafio)

Uma vez que a Conscientização dos Usuários é o principal desafio, o foco deve ser na qualidade e periodicidade dos treinamentos:

- **Simulação de Phishing:** Implementar campanhas de *phishing* simulado de forma contínua e imprevisível. O foco não é punir, mas identificar e oferecer treinamento direcionado aos usuários que falharem.
- **Comunicação Frequente:** Criar alertas de segurança curtos e frequentes (*microlearning*) sobre temas específicos (ex: "Sextou! Pense antes de clicar").
- **Uso de KeePass ou similar:** Recomendar o uso de um gerenciador de senhas (como o KeePass), para facilitar o uso de senhas longas e complexas, aliviando a carga cognitiva do usuário.